

ESPECIFICAÇÃO TÉCNICA DE IMPLANTAÇÃO

Convergência com ISO/IEC 27001:2022 & Diretiva NIS 2 (UE 2022/2555)

RIDIS — Sistema de Gestão de Discos USB, Matrizes e Relatórios de Preservação Digital

Autor / Responsável Técnico:	José Miguel Magalhães (Direitos Reservados)
Entidade Titular da Licença:	DGLAB — Direção-Geral do Livro, dos Arquivos e das Bibliotecas
Data de Homologação:	Outubro de 2026 Versão 1.0.0 (Produção)

0. Matriz de Convergência Normativa: ISO 27001 / NIS 2

O sistema RIDIS operacionaliza a cadeia de custódia e validação de discos USB externos nos arquivos da DGLAB (ANTT, Arquivos Distritais). Devido à relevância patrimonial e documental, a sua arquitetura foi alinhada de raiz aos controlos da norma internacional ISO/IEC 27001:2022 e às exigências de resiliência da Diretiva NIS 2 (Diretiva UE 2022/2555 / Regime Jurídico de Cibersegurança nacional).

Domínio Normativo	Controlo ISO 27001:2022 / NIS 2	Implementação Técnica no RIDIS
Acesso & Privilégios	ISO A.5.15 / A.8.2 NIS2 Art.21(2)(i)	Contas RBAC, passwords com SHA-256/salt, processo sem root (ridis).
Proteção em Trânsito	ISO A.8.24 / A.8.20 NIS2 Art.21(2)(h)	Nginx HTTPS obrigatório, TLS 1.3, HSTS estrito e isolamento perimétrico.
Continuidade & Dados	ISO A.8.13 NIS2 Art.21(2)(c)	Base de dados SQLite em modo WAL, backups comprimidos e checagem PRAGMA.
Segurança na Aplicação	ISO A.8.26 / A.8.28 NIS2 Art.21(2)(e)	Sanitização rigorosa de ficheiros, transações atómicas e limites de upload (50MB).
Deteção e Auditoria	ISO A.8.16 / A.8.9 NIS2 Art.21(2)(b)	Logs estruturados em journald, rate-limiting anti-força bruta em /api/login.

As secções seguintes detalham o roteiro técnico imperativo de instalação, scripts de base de dados, configuração de servidores Web, inventário de ficheiros e parametrizações operacionais recomendadas.

1. Pacotes de Software Necessários Instalar

Para garantir a conformidade e estabilidade a longo prazo, a infraestrutura deve assentar numa distribuição Linux de suporte alargado (LTS). O runtime de aplicação exige o Node.js v22 LTS devido ao motor integrado de alto rendimento node:sqlite.

1.1 Sistema Operativo Recomendado

- Distribuição Homologada: Ubuntu Server 24.04 LTS (Noble Numbat) ou Debian 12 (Bookworm) / RHEL 9.
- Dimensionamento Mínimo: 2 vCPUs, 4 GB de RAM, 50 GB SSD (com partição /var/www cifrada por LUKS).
- Gestão de Utilizadores: Criação do utilizador de sistema dedicado "ridis" sem permissões de login interativo.

1.2 Comandos de Instalação de Pacotes do Sistema (APT)

```
# 1. Atualizar índice de repositórios oficiais e aplicar patches de segurança
sudo apt update && sudo apt upgrade -y

# 2. Instalar utilitários essenciais, compilação, base de dados e segurança
sudo apt install -y curl wget git build-essential ca-certificates gnupg \
lsb-release sqlite3 libsqlite3-dev nginx ufw fail2ban logrotate rsyslog gzip unzip openssl
```

1.3 Instalação do Runtime Node.js (Versão 22 LTS)

```
# Configurar repositório NodeSource para Node.js v22.x LTS e instalar
curl -fsSL https://deb.nodesource.com/setup_22.x | sudo -E bash -
sudo apt install -y nodejs

# Validar versões instaladas
node -v # Output esperado: v22.x.x
npm -v # Output esperado: v10.x.x ou superior
```

1.4 Dependências de Aplicação Node.js / npm (package.json)

A aplicação utiliza dependências modulares e consolidadas, sem ferramentas ou bibliotecas proprietárias de terceiros:

- **express (v4.21+)**: Servidor HTTP de aplicação e roteamento da API REST institucional
- **vite (v8.3+)**: Bundler de desenvolvimento e produção para a SPA React
- **multer (v2.4+)**: Tratamento de uploads de relatórios de texto de discos com limite restrito
- **react & react-dom (v19)**: Interface de utilizador SPA reativa, responsiva e acessível
- **lucide-react & motion**: Iconografia vetorial SVG embutida e transições sem assets externos
- **pdfkit (v0.17+)**: Gerador de relatórios técnicos e documentos de conformidade vetoriais
- **tsx & typescript (v7)**: Execução TypeScript de alta performance e verificação estática rigorosa

```
# No diretório /var/www/ridis:
cd /var/www/ridis && npm ci --omit=dev # Instalação limpa para produção
```

2. Base de Dados a Instalar e Script de Criação

A base de dados adotada é o SQLite 3 com modo avançado WAL (Write-Ahead Logging). O SQLite é uma base de dados ACID, auto-contida e sem necessidade de porta de rede aberta no sistema operacional, reduzindo drasticamente a superfície de ataque em conformidade com a ISO/IEC 27001 A.8.20 e NIS 2.

2.1 Diretrizes de Segurança da Base de Dados

- Localização Operacional: /var/www/ridis/gestao_discos.db
- Permissões de Ficheiro: chmod 660 (leitura/escrita exclusiva pelo utilizador ridis:ridis).
- Cifragem em Repouso (ISO 27001 A.8.24): Recomenda-se alojar o ficheiro num volume encriptado com LUKS 2.
- Integridade Transacional: PRAGMA journal_mode = WAL e PRAGMA synchronous = NORMAL.

2.2 Script SQL de Criação e Inicialização da Base de Dados

O script encontra-se disponível no ficheiro /var/www/ridis/deploy/schema_criacao_bd.sql e deve ser executado para instanciar a estrutura:

```
-- Ativação de Modos de Segurança e Integridade
PRAGMA journal_mode = WAL;
PRAGMA synchronous = NORMAL;
PRAGMA foreign_keys = ON;

-- Tabela de Discos USB (Inventário Físico/Lógico de Preservação)
CREATE TABLE IF NOT EXISTS discos_usb (
  id INTEGER PRIMARY KEY AUTOINCREMENT,
  arquivo TEXT NOT NULL,           -- ANTT, ADAVR, ADBJA, etc.
  remetente TEXT, data_entrada TEXT, ticket_num TEXT,
  id_disco TEXT UNIQUE NOT NULL,   -- Identificador unívoco do disco
  localizacao TEXT, tamanho_disco TEXT, marca TEXT, numero_serie TEXT,
  verificado INTEGER DEFAULT 0, ticket_integracao TEXT,
  integrado INTEGER DEFAULT 0, armazenado_servidor INTEGER DEFAULT 0,
  total_imagens INTEGER DEFAULT 0, observacoes TEXT,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  projeto TEXT, relatorio_path TEXT
);

-- Tabela de Utilizadores e RBAC
CREATE TABLE IF NOT EXISTS usuarios (
  id INTEGER PRIMARY KEY AUTOINCREMENT,
  username TEXT UNIQUE NOT NULL,
  password_hash TEXT NOT NULL,     -- Hash criptográfico SHA256 com salt
  is_admin INTEGER DEFAULT 0,
  role TEXT DEFAULT 'operador',
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);

-- Tabela de Ficheiros e Matrizes Digitais Indexadas
CREATE TABLE IF NOT EXISTS relatorio_ficheiros (
  id INTEGER PRIMARY KEY AUTOINCREMENT,
  disco_id INTEGER NOT NULL,
  nome_ficheiro TEXT NOT NULL,
  tamanho_bytes INTEGER DEFAULT 0,
  pasta TEXT DEFAULT '',
  FOREIGN KEY (disco_id) REFERENCES discos_usb(id) ON DELETE CASCADE
);

-- Índices Otimizados para Prevenção de Exaustão de Recursos
CREATE INDEX IF NOT EXISTS idx_discos_id_disco ON discos_usb(id_disco);
CREATE INDEX IF NOT EXISTS idx_discos_arquivo ON discos_usb(arquivo);
CREATE INDEX IF NOT EXISTS idx_ficheiros_disco_id ON relatorio_ficheiros(disco_id);
CREATE INDEX IF NOT EXISTS idx_ficheiros_nome ON relatorio_ficheiros(nome_ficheiro);
```

2.3 Procedimento Operacional de Execução

```
# Executar criação da base de dados via CLI
sqlite3 /var/www/ridis/gestao_discos.db < /var/www/ridis/deploy/schema_criacao_bd.sql

# Assegurar propriedades de segurança no ficheiro
sudo chown ridis:ridis /var/www/ridis/gestao_discos.db*
sudo chmod 660 /var/www/ridis/gestao_discos.db*
```

3. Web Server a Instalar: Nginx (Reverse Proxy & Hardening)

O Nginx é posicionado como barreira de segurança perimétrica entre a rede da DGLAB e a aplicação Node.js (escutando na porta interna 3005). Ele efetua a terminação TLS 1.3, rate limiting contra ataques de negação de serviço ou força bruta, e aplica cabeçalhos estritos de segurança.

3.1 Ficheiro de Configuração Nginx (/etc/nginx/sites-available/ridis.conf)

```
# Zonas de limitação de taxa (Mitigação de DoS e Força Bruta)
limit_req_zone $binary_remote_addr zone=ridis_api_limit:10m rate=30r/s;
limit_req_zone $binary_remote_addr zone=ridis_login_limit:10m rate=5r/m;

upstream ridis_backend {
    server 127.0.0.1:3005 max_fails=3 fail_timeout=10s;
    keepalive 32;
}

# 1. Redirecionamento HTTP -> HTTPS (ISO 27001 A.8.24)
server {
    listen 80; listen [::]:80;
    server_name ridis.dglab.gov.pt;
    server_tokens off;
    return 301 https://$host$request_uri;
}

# 2. Servidor Seguro HTTPS (TLS 1.3 Estrito)
server {
    listen 443 ssl http2; listen [::]:443 ssl http2;
    server_name ridis.dglab.gov.pt;
    server_tokens off;

    ssl_certificate /etc/ssl/certs/ridis_dglab.crt;
    ssl_certificate_key /etc/ssl/private/ridis_dglab.key;
    ssl_protocols TLSv1.2 TLSv1.3;
    ssl_ciphers 'ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256:ECDHE-ECDSA-AES256-GCM-SHA384';
    ssl_prefer_server_ciphers on;

    # Cabeçalhos de Segurança Obrigatórios ISO 27001 / OWASP
    add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
    add_header X-Frame-Options "SAMEORIGIN" always;
    add_header X-Content-Type-Options "nosniff" always;
    add_header Referrer-Policy "strict-origin-when-cross-origin" always;
    add_header Content-Security-Policy "default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data:; font-src 'self' data:; connect-src 'self';" always;

    client_max_body_size 50M; # Limite para uploads de relatórios

    # Proteção de Autenticação contra Brute-Force (NIS 2)
    location = /api/login {
        limit_req zone=ridis_login_limit burst=5 nodelay;
        proxy_pass http://ridis_backend;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
    }

    # Proxy Geral da Aplicação e API
    location / {
        limit_req zone=ridis_api_limit burst=50 nodelay;
        proxy_pass http://ridis_backend;
        proxy_http_version 1.1;
        proxy_set_header X-Real-IP $remote_addr;
    }
}
```

3.2 Ativação e Verificação do Nginx

```
sudo ln -sf /etc/nginx/sites-available/ridis.conf /etc/nginx/sites-enabled/
sudo nginx -t && sudo systemctl reload nginx
```

4. Conjunto de Ficheiros de Cada Aplicação e Permissões POSIX

De acordo com o Princípio do Menor Privilégio (ISO/IEC 27001 A.8.2 e A.8.9), cada ficheiro e pasta do sistema RIDIS possui finalidade estrita e permissões granulares no sistema de ficheiros para mitigar riscos de escalada de privilégios ou adulteração maliciosa.

4.1 Inventário Estrutural de Ficheiros

Ficheiro / Diretório	Função Operacional e Descrição	Permissão POSIX
/var/www/ridis/server.ts	Backend Express, API REST, SQLite engine e Vite middleware	640 (ridis:ridis)
/var/www/ridis/gestao_discos.db*	Base de dados SQLite operacional (dados, WAL e SHM)	660 (ridis:ridis)
/var/www/ridis/.env	Variáveis de ambiente (PORT=3005, segredos)	600 (ridis:ridis)
/var/www/ridis/relatorios/	Diretório de receção de relatórios de validação carregados	770 (ridis:ridis)
/var/www/ridis/backups/	Diretório de cópias de segurança comprimidas (.db.gz)	750 (ridis:ridis)
/var/www/ridis/deploy/	Scripts de automação: DDL, Nginx, systemd e documentação	750 (ridis:ridis)
/var/www/ridis/src/App.tsx	Interface reativa completa do utilizador (React TypeScript)	640 (ridis:ridis)
/var/www/ridis/public/	Ativos estáticos públicos e PDF técnico de conformidade	750 (ridis:ridis)
/var/www/ridis/LICENSE / LICENCA.md	Termos legais de Direitos de Autor exclusivos DGLAB	644 (ridis:ridis)

4.2 Script de Aplicação de Permissões de Segurança

```
# Criação do utilizador de sistema seguro e restrição total
sudo useradd -r -s /usr/sbin/nologin -d /var/www/ridis ridis
sudo chown -R ridis:ridis /var/www/ridis
sudo find /var/www/ridis -type d -exec chmod 750 {} +
sudo find /var/www/ridis -type f -exec chmod 640 {} +
sudo chmod 770 /var/www/ridis/relatorios /var/www/ridis/backups
sudo chmod 660 /var/www/ridis/gestao_discos.db*
sudo chmod 600 /var/www/ridis/.env
```

5. Configurações a Aplicar: Systemd, Firewall e Resposta a Incidentes

A governação e operação em produção necessitam da integração do processo no gestor de serviços systemd com sandboxing rigoroso, proteção de tráfego por firewall e planos de cópias de segurança automáticas.

5.1 Unidade de Serviço Systemd com Sandboxing (/etc/systemd/system/ridis.service)

```
[Unit]
Description=RIDIS – Gestao de Discos USB e Preservacao Digital (DGLAB)
After=network.target network-online.target

[Service]
Type=simple
User=ridis
Group=ridis
WorkingDirectory=/var/www/ridis
EnvironmentFile=-/var/www/ridis/.env
ExecStart=/usr/bin/node /var/www/ridis/node_modules/.bin/tsx /var/www/ridis/server.ts

# Resiliência e Continuidade (NIS 2)
Restart=always
RestartSec=5s

# Sandboxing Estrito de Sistema de Ficheiros e Processos (ISO 27001 A.8.9)
NoNewPrivileges=true
ProtectSystem=strict
ProtectHome=true
PrivateTmp=true
ProtectKernelTunables=true
ProtectKernelModules=true
ReadWritePaths=/var/www/ridis/gestao_discos.db /var/www/ridis/gestao_discos.db-wal /var/www/ridis/gestao_discos.db-shm /var/www/ridis/relatorios /var/www/ridis/backups

StandardOutput=journal
StandardError=journal
SyslogIdentifier=ridis-dglab
```

5.2 Ativação do Serviço

```
sudo systemctl daemon-reload
sudo systemctl enable --now ridis.service
sudo systemctl status ridis.service
```

5.3 Firewall UFW e Isolamento Perimétrico

```
sudo ufw default deny incoming && sudo ufw default allow outgoing
sudo ufw allow from 10.0.0.0/8 to any port 22 proto tcp comment 'SSH DGLAB VPN'
sudo ufw allow 80/tcp comment 'Nginx HTTP Redirect'
sudo ufw allow 443/tcp comment 'Nginx HTTPS TLS'
sudo ufw enable
```

5.4 Política de Cópias de Segurança e Notificação de Incidentes (NIS 2)

- Política de Backup (Cronjob Diário às 02h00): Execução de sqlite3 .backup com compressão gzip e retenção de 90 dias em /etc/cron.d/ridis-backup.
- Notificação de Incidentes NIS 2 (Artigo 23.º): Qualquer incidente que ameace a custódia ou integridade dos registos de preservação digital obriga a notificação prévia em 24 horas à equipa interna e notificação detalhada em 72 horas ao Centro Nacional de Cibersegurança (CNCS).

TERMO DE CONFORMIDADE E HOMOLOGAÇÃO TÉCNICA

Este documento constitui o guia oficial de implantação técnica do RIDIS no ambiente da DGLAB. O sistema cumpre integralmente os requisitos de proteção de dados, controlo de acessos e resiliência das normas ISO/IEC 27001:2022 e da Diretiva NIS 2.

Autor: José Miguel Magalhães · DGLAB / Serviços Centrais (2026)

